

PHASE 6 — QUANTUM RISK ASSESSMENT & MOSCA'S METHOD

Project: Enterprise Cryptographic Discovery & Analysis Tool (ECDAT)

Problem Statement: SIH26164

Organization: National Technical Research Organisation (NTRO)

Theme: Blockchain & Cybersecurity

Phase: 6 of 22

Document Type: Technical Research & Engineering Handbook

Status: Quantum Risk Engine Foundation

Table of Contents

1. Purpose of This Phase
2. From Discovery to Risk
3. Why "Quantum Vulnerable" Is Not Enough
4. The Three Variables of Quantum Risk
5. Mosca's Inequality
6. Data Lifetime
7. Migration Time
8. Quantum Threat Horizon
9. Interpreting $X + Y > Z$
10. Example 1
11. Example 2
12. Example 3
13. Harvest Now, Decrypt Later
14. Why HNDL Changes Risk
15. Data Sensitivity
16. Business Criticality
17. Exposure
18. Cryptographic Function
19. Algorithm Strength
20. Key Size
21. Protocol Context

22. Implementation Risk
23. Dependency Risk
24. Migration Complexity
25. Crypto-Agility
26. Asset Confidence
27. Risk Is Not the Same as Vulnerability
28. ECDAT Quantum Risk Model
29. Risk Dimensions
30. Base Quantum Risk
31. Business Impact
32. Exposure Multiplier
33. Data Lifetime Factor
34. Migration Complexity Factor
35. Confidence Adjustment
36. Dependency Propagation
37. Critical Infrastructure
38. Internet-Facing Systems
39. Long-Lived Data
40. Government Data
41. Financial Data
42. Healthcare Data
43. Intellectual Property
44. Cryptographic Keys
45. Certificates
46. Signatures
47. Key Exchange
48. Symmetric Cryptography
49. Hash Functions
50. Risk Categories
51. Critical
52. High
53. Medium
54. Low

- 55. Informational
 - 56. Risk Matrix
 - 57. Prioritization
 - 58. Risk Ranking
 - 59. Example ECDAT Findings
 - 60. Enterprise Risk Dashboard
 - 61. Risk Propagation Through a Graph
 - 62. "What Breaks If This Crypto Breaks?"
 - 63. Scenario Analysis
 - 64. Best-Case Scenario
 - 65. Expected Scenario
 - 66. Worst-Case Scenario
 - 67. Threat Horizon Uncertainty
 - 68. Risk Decay and Time
 - 69. Migration Deadline
 - 70. Technical Debt
 - 71. Quantum Exposure Score
 - 72. Migration Readiness Score
 - 73. Crypto-Agility Score
 - 74. Overall Quantum Readiness
 - 75. Executive Reporting
 - 76. Risk Explainability
 - 77. Evidence-Based Scoring
 - 78. Avoiding Arbitrary AI Scores
 - 79. AI's Role in Risk Assessment
 - 80. Requirements Derived From Phase 6
 - 81. Complete Risk Pipeline
 - 82. Phase 6 Summary
 - 83. Phase 7 Preview
-

1. Purpose of This Phase

The previous phases established:



Now ECDAT has a major problem.

Suppose the scanner discovers:

100,000 cryptographic assets

Does that mean all 100,000 need immediate migration?

Absolutely not.

Some may be:

- Low-value
- Short-lived
- Non-sensitive
- Already protected through another mechanism
- Experimental
- Offline
- Easy to migrate

Others may protect:

- National identity information
- Government secrets
- Financial systems
- Military information
- Critical infrastructure
- Long-term intellectual property

Therefore ECDAT needs a mechanism to answer:

Which cryptographic assets create the greatest quantum risk, and why?

That is the purpose of the Phase 6 risk engine.

2. From Discovery to Risk

Discovery tells us:

What exists?

Risk analysis asks:

What matters?

For example:

Asset A
RSA-2048
Internal test server
Data lifetime: 1 year

versus:

Asset B
RSA-2048
National identity system
Data lifetime: 30 years
Internet-facing
Critical infrastructure

Technically:

Same algorithm

But operationally:

Completely different risk

Therefore:

Quantum risk is contextual.

3. Why "Quantum Vulnerable" Is Not Enough

A simplistic scanner might produce:

```
RSA-2048 → Quantum Vulnerable → HIGH
```

This is inadequate.

Consider:

```
RSA-2048
```

used to sign:

```
Temporary development logs
```

versus:

```
RSA-2048
```

used to sign:

```
National identity certificates
```

The cryptographic primitive may be the same.

The consequences are radically different.

ECDAT must therefore calculate risk from multiple dimensions.

4. The Three Variables of Quantum Risk

One of the most important concepts in the problem statement is:

```
Mosca's algorithm.
```

The underlying idea can be represented as:

```
X + Y > Z
```

Where conceptually:

```
X = Data / information lifetime
```

```
Y = Migration / replacement time
```

Z = Time until cryptographically relevant
quantum capability becomes available

If:

$$X + Y > Z$$

then the organization may already be inside its required migration window.

5. Mosca's Inequality

Mosca's theorem is commonly used as a strategic framework for quantum-readiness planning.

The basic intuition:

If the lifetime of protected information plus the time required to migrate exceeds the expected time until a sufficiently capable quantum computer exists, migration needs to begin now.

Represented as:

$$\begin{array}{c} X \\ \text{Data Lifetime} \\ + \\ Y \\ \text{Migration Time} \\ > \\ Z \\ \text{Quantum Threat Horizon} \end{array}$$

Therefore:

$$X + Y > Z$$

means:

Start migrating.

6. Data Lifetime

The first variable is:

X = Data Lifetime

Ask:

How long does this information need to remain confidential or trustworthy?

Examples:

Temporary session data

→ minutes/hours

Operational logs

→ months

Customer records

→ years

Financial records

→ 7–10+ years

Government records

→ decades

Strategic information

→ potentially decades

The longer the data lifetime, the more important future cryptographic threats become.

7. Migration Time

The second variable:

Y = Migration Time

This is not simply:

"How long does it take to change the algorithm?"

It includes:

Discovery

+

Design

+

Vendor coordination

+


```
Testing
+
Certification
+
Deployment
+
Client migration
+
Legacy retirement
```

For a simple application:

```
Y = months
```

For a national-scale infrastructure:

```
Y = years
```

This is why migration planning must begin early.

8. Quantum Threat Horizon

The third variable:

Z = Quantum Threat Horizon

This represents the estimated time until a cryptographically relevant quantum computer could threaten the relevant cryptographic mechanism.

This is inherently uncertain.

ECDAT must **not** pretend that Z is a known exact date.

Instead, it should support:

```
Best Estimate
Confidence Range
Scenario Range
```

For example:

```
Optimistic:
Later quantum capability

Expected:
```

Intermediate estimate

Conservative:

Earlier quantum capability

9. Interpreting $X + Y > Z$

Consider:

Data Lifetime = 15 years

Migration Time = 8 years

Quantum Threat Horizon = 20 years

Then:

$15 + 8 = 23$

$23 > 20$

Therefore:

Migration should begin.

Even though the quantum threat may be 20 years away.

This is the key strategic insight.

10. Example 1 — Low Strategic Risk

Suppose:

Data lifetime:

1 year

Migration time:

6 months

Quantum horizon:

15 years

Then:

$$1 + 0.5 = 1.5$$

$$1.5 < 15$$

The Mosca condition is not triggered.

This does **not** mean:

"RSA is safe."

It means:

This particular asset may not be among the earliest migration priorities based on lifetime and migration horizon.

11. Example 2 — High Strategic Risk

Suppose:

Data lifetime:

20 years

Migration time:

5 years

Quantum horizon:

15 years

Then:

$$20 + 5 = 25$$

$$25 > 15$$

Migration planning is urgent.

12. Example 3 — Extremely Long-Lived Data

Suppose:

Data lifetime:

40 years

Migration time:

10 years

Quantum horizon:

20 years

Then:

$40 + 10 = 50$

$50 > 20$

The system is clearly inside the migration window.

13. Harvest Now, Decrypt Later

A major reason quantum risk exists today is:

HNDL

Harvest Now, Decrypt Later

The attacker may:

Today

↓

Capture encrypted traffic

↓

Store it

↓

Wait for quantum capability

↓

Decrypt later

Therefore:

The fact that quantum computers capable of breaking the encryption do not exist today does not necessarily eliminate today's risk.

14. Why HNDL Changes Risk

Consider sensitive diplomatic communication.

Encrypted in 2026

Suppose:

Data remains sensitive until 2050.

An attacker can collect it today.

If a sufficiently capable quantum computer becomes available before 2050, the attacker may potentially decrypt the captured material.

This makes long-lived confidentiality especially important.

ECDAT should therefore identify:

- High-value data
- +
- Long retention
- +
- Quantum-vulnerable public-key encryption

as a major risk category.

15. Data Sensitivity

Not all data deserves the same priority.

ECDAT should support configurable classifications.

Example:

- Public
- Internal
- Confidential
- Sensitive
- Highly Sensitive
- Strategic

A quantum-vulnerable algorithm protecting public information should generally rank lower than the same algorithm protecting strategic information.

16. Business Criticality

A cryptographic asset may be technically vulnerable but operationally insignificant.

Another may protect the organization's most important service.

Example:

Application A
Business Criticality:
Low

versus:

Application B
Business Criticality:
Mission Critical

ECDAT should incorporate this dimension.

17. Exposure

Exposure describes how reachable the asset is.

Possible levels:

Internet
External Partner
Corporate Network
Restricted Network
Isolated
Offline

An internet-facing service generally deserves more urgent attention than an isolated development environment.

18. Cryptographic Function

Not every cryptographic function faces identical quantum consequences.

ECDAT should distinguish:

Key Establishment
Digital Signature
Encryption
Hashing
Authentication
Integrity
Key Wrapping
Certificate Signing
Code Signing

This allows function-specific risk analysis.

19. Algorithm Strength

ECDAT should capture:

```
Algorithm
Parameter Set
Key Size
Mode
Version
```

Example:

```
RSA-1024
```

and:

```
RSA-4096
```

are not identical from a classical security perspective.

However, both remain fundamentally vulnerable to a sufficiently capable quantum computer because the underlying mathematical problem is affected by Shor's algorithm.

This is a critical distinction:

```
Increasing the RSA key size does not make RSA post-quantum secure.
```

20. Key Size

Key size should still be recorded.

Examples:

```
RSA-2048
RSA-3072
RSA-4096

ECC P-256
ECC P-384
ECC P-521
```

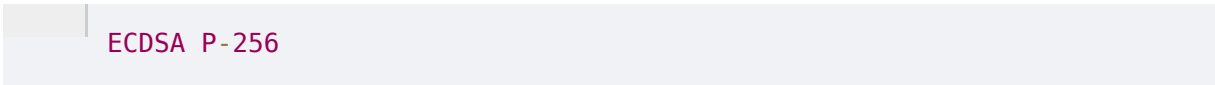
Key size affects classical security and performance.

It does not eliminate the fundamental quantum threat to vulnerable public-key families.

21. Protocol Context

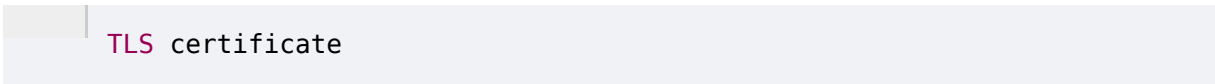
Algorithm risk also depends on protocol context.

Example:



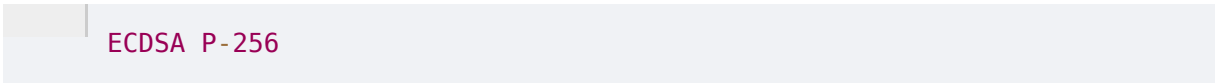
ECDSA P-256

used for:



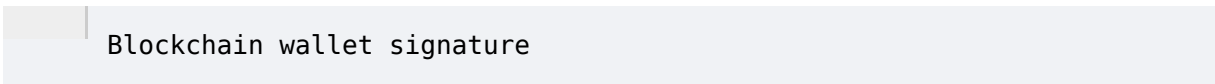
TLS certificate

is different from:



ECDSA P-256

used for:



Blockchain wallet signature

The migration mechanisms differ.

Therefore ECDAT must preserve protocol context.

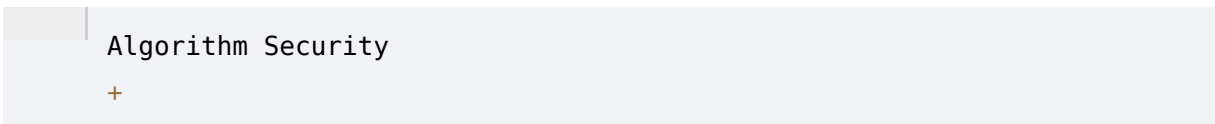
22. Implementation Risk

Even a strong algorithm can be implemented badly.

Potential problems:

- Weak randomness
- Side-channel leakage
- Incorrect key storage
- Improper padding
- Bad parameter handling
- Deprecated modes
- Hardcoded keys

Therefore:



Algorithm Security

+

must both be considered.

23. Dependency Risk

A cryptographic asset may depend on another component.

Example:

```
Application
↓
Crypto Library
↓
OpenSSL
↓
Operating System
```

If the application cannot update OpenSSL without updating the OS, migration becomes more complex.

ECDAT should therefore model dependency relationships.

24. Migration Complexity

This is one of the most important variables.

Migration complexity may depend on:

```
Number of Dependencies
+
Protocol Constraints
+
Hardware Dependencies
+
Vendor Dependencies
+
Certification
+
Client Compatibility
+
Downtime Requirements
```

A simple application might have:

Migration Complexity = Low

A national infrastructure system:

Migration Complexity = Very High

25. Crypto-Agility

Crypto-agility dramatically changes migration risk.

Highly agile system:

Algorithm configurable

Low agility:

Algorithm hardcoded

Very low agility:

Algorithm embedded in hardware firmware

Therefore ECDAT should calculate:

Crypto-Agility Score

Example:

0 = Extremely rigid
1 = Low
2 = Moderate
3 = Good
4 = High
5 = Excellent

The exact scale should be configurable.

26. Asset Confidence

Suppose ECDAT detects:

RSA

with only:

```
String Match
```

Confidence might be low.

But if the system has:

```
Certificate Parsing
```

```
+
```

```
Binary Symbols
```

```
+
```

```
Runtime Observation
```

confidence is much higher.

Risk should incorporate this uncertainty.

27. Risk Is Not the Same as Vulnerability

This distinction is essential.

Vulnerability

```
The algorithm is susceptible to a known class of attack.
```

Risk

```
The likelihood and consequence of that vulnerability  
affecting this specific business asset.
```

Therefore:

```
Quantum Vulnerability
```

```
≠
```

```
Quantum Risk
```

28. ECDAT Quantum Risk Model

ECDAT should calculate risk from several dimensions.

Conceptually:

```
Quantum Risk
```

```
=
```

```
Cryptographic Exposure
```

```
×
```

```
Data Value
×
Time Exposure
×
Business Impact
×
Migration Difficulty
×
Threat Uncertainty
```

This is a conceptual model.

The final implementation should be calibrated and validated rather than using arbitrary multipliers.

29. Risk Dimensions

Recommended dimensions:

1. Quantum Vulnerability
2. Data Sensitivity
3. Data Lifetime
4. Business Criticality
5. Exposure
6. Migration Complexity
7. Crypto-Agility
8. Dependency Centrality
9. Asset Confidence
10. Threat Horizon

30. Base Quantum Risk

Start with the algorithm.

Example:

```
Algorithm:
ECDSA P-256

Quantum Status:
Vulnerable
```

Base classification:

Quantum Exposure:
High

But don't immediately conclude:

Overall Risk:
High

More context is required.

31. Business Impact

Suppose:

Application:
National Identity Platform

Algorithm:
ECDSA

If the signature mechanism were compromised, consequences could include:

- Identity impersonation
- Trust-chain compromise
- Unauthorized access
- Fraud

Business impact becomes extremely high.

32. Exposure Multiplier

A useful conceptual model:

Exposure
|
├─ Internet
├─ Partner
├─ Internal
├─ Restricted
└─ Isolated

Internet-facing systems generally deserve more attention.

However, isolated systems can still be critical if they protect high-value data.

Therefore exposure should not dominate the entire model.

33. Data Lifetime Factor

Consider:

```
Data Lifetime = 1 year
```

versus:

```
Data Lifetime = 40 years
```

The second creates substantially greater HNDL exposure.

ECDAT should therefore use lifetime as a first-class risk variable.

34. Migration Complexity Factor

Suppose:

```
System A:  
Migration = 3 months
```

and:

```
System B:  
Migration = 8 years
```

Even if both have similar cryptographic exposure, System B may need to start much earlier.

This is where Mosca's method becomes powerful.

35. Confidence Adjustment

Suppose:

```
Finding:  
RSA  
  
Confidence:  
0.55
```

ECDAT should not pretend this is equivalent to:

Confidence:

0.99

The system should expose uncertainty.

For example:

Risk:

High

Confidence:

Medium

This is better than:

Risk:

High

with no explanation.

36. Dependency Propagation

Imagine:

HSM

↓

CA

↓

Certificate

↓

100 Applications

If the HSM cannot support the required PQC transition, the migration risk affects all dependent systems.

Therefore ECDAT should propagate dependency impact.

This is a graph problem.

37. Critical Infrastructure

Critical infrastructure deserves special treatment.

Examples:

- Energy
- Telecommunications
- Banking
- Government services
- Transportation
- Defense
- Water systems

For such assets:

```
Business Criticality
=
Very High
```

and migration timelines may need to be more conservative.

38. Internet-Facing Systems

Internet-facing assets should receive higher exposure consideration.

Example:

```
Internet
↓
Load Balancer
↓
TLS
↓
Application
```

A quantum-vulnerable certificate or key exchange mechanism may affect the public trust boundary.

39. Long-Lived Data

Long-lived sensitive data should be prioritized.

Examples:

```
Government identity records
Strategic research
Medical records
Financial histories
```


Intellectual property
Diplomatic information

The key question:

Will the data still be sensitive when quantum attacks become practical?

If yes, HNDL becomes relevant.

40. Government Data

Government systems may have unusually long information lifetimes.

For example:

Record Created:

2026

Retention:

30 years

Sensitivity:

High

ECDAT should therefore support long retention periods.

41. Financial Data

Financial systems often contain:

- Transaction records
- Account information
- Identity information
- Payment data
- Cryptographic keys

Many systems also have strict availability and compliance requirements.

Therefore migration complexity can be significant.

42. Healthcare Data

Healthcare data can have long-term sensitivity.

Records may remain private for decades.

Therefore:

Long Data Lifetime

+

Sensitive Data

creates elevated quantum planning importance.

43. Intellectual Property

Some intellectual property remains valuable for decades.

Examples:

- Research
- Engineering designs
- Algorithms
- Industrial processes
- Strategic plans

Even if the data is not immediately exploitable, long-term confidentiality matters.

44. Cryptographic Keys

Keys deserve special attention.

A compromised key may affect:

Thousands of transactions

Millions of certificates

Entire trust chains

ECDAT should therefore calculate key centrality.

45. Certificates

A certificate may be used by:

1 server

or:

10,000 endpoints

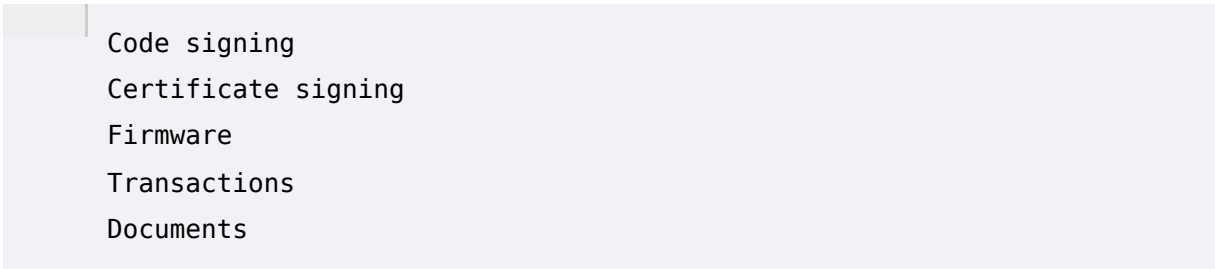
The impact differs dramatically.

ECDAT should track certificate usage and dependency count.

46. Signatures

Signature systems protect trust.

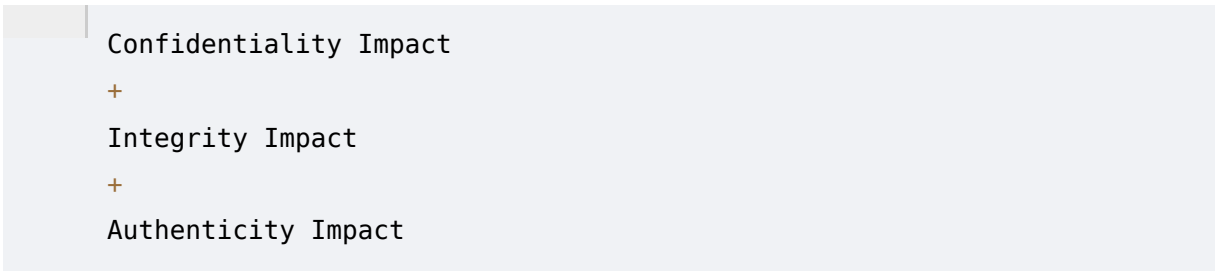
Examples:



```
Code signing
Certificate signing
Firmware
Transactions
Documents
```

Quantum compromise of signatures can potentially affect authenticity rather than confidentiality.

Therefore risk should account for:



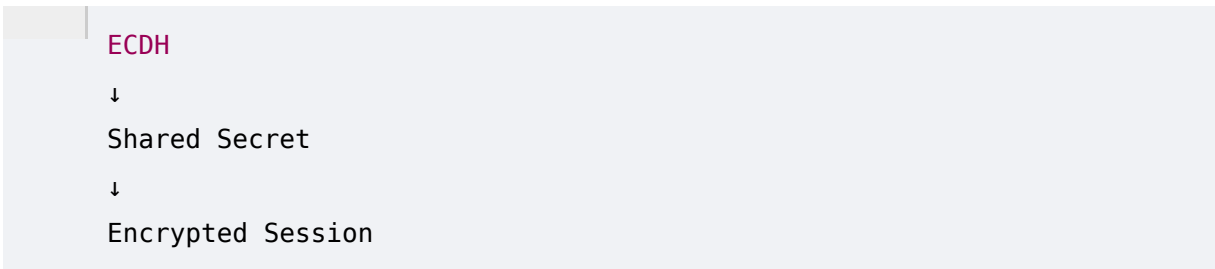
```
Confidentiality Impact
+
Integrity Impact
+
Authenticity Impact
```

47. Key Exchange

Quantum attacks against public-key key exchange threaten confidentiality.

This is particularly relevant to HNDL.

Example:



```
ECDH
↓
Shared Secret
↓
Encrypted Session
```

If historical traffic was recorded, future cryptanalytic capability may threaten confidentiality.

48. Symmetric Cryptography

Symmetric cryptography is affected differently by quantum computing.

Grover's algorithm provides a quadratic speedup for generic brute-force search.

This does not mean:

AES-256
=
Broken

Instead, the quantum security margin is reduced compared with classical brute force.

This is why ECDAT must avoid treating symmetric and public-key cryptography identically.

49. Hash Functions

Quantum search can also affect generic preimage resistance.

But the implications depend on:

- Hash function
- Output size
- Usage
- Security requirement

Again:

Quantum risk is function-specific.

50. Risk Categories

ECDAT can classify findings into:

CRITICAL
HIGH
MEDIUM
LOW
INFORMATIONAL

These categories should be configurable.

51. Critical

Possible characteristics:

Quantum-vulnerable
+
Mission-critical
+
Highly sensitive data
+
Long lifetime
+
Migration > threat window

Example:

National identity trust infrastructure

52. High

Possible characteristics:

Quantum-vulnerable
+
Important business service
+
Significant data lifetime
+
Migration required

Example:

Internet-facing financial API

53. Medium

Possible characteristics:

Quantum-vulnerable
+
Moderate sensitivity
+
Shorter lifetime
+
Low migration complexity

54. Low

Possible characteristics:

- Low-value data
- +
- Short lifetime
- +
- Low criticality
- +
- Easy migration

55. Informational

Examples:

- PQC-ready
- Crypto-agile
- No significant quantum concern

Informational does not mean useless.

It can show organizational maturity.

56. Risk Matrix

A simple matrix:

Impact	Low Likelihood	Medium Likelihood	High Likelihood
Low	Low	Low	Medium
Medium	Low	Medium	High
High	Medium	High	Critical
Extreme	High	Critical	Critical

But ECDAT should eventually use a richer model than a simple 2D matrix.

57. Prioritization

The objective is not:

Fix everything immediately.

The objective is:

Fix the most consequential assets first.

A priority list could look like:

P0

Immediate Strategic Attention

P1

Near-Term Migration Planning

P2

Migration Preparation

P3

Monitor

P4

Informational

58. Risk Ranking

Example:

Asset	Algorithm	Data Lifetime	Criticality	Migration	Risk
National CA	RSA	30y	Critical	8y	Critical
Payment API	ECDSA	15y	Critical	4y	High

Internal App	RSA	2y	Medium	1y	Medium
Test Server	RSA	3mo	Low	1mo	Low

This is much more actionable than a raw algorithm list.

59. Example ECDAT Finding

CRYPTOGRAPHIC RISK FINDING

Asset:

National Identity CA

Algorithm:

RSA-3072

Function:

Certificate Signing

Exposure:

Critical Infrastructure

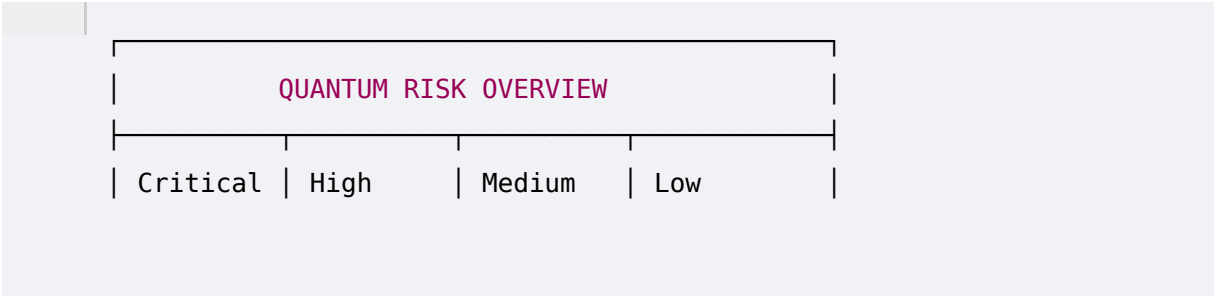
Data / Trust Lifetime:

20 years

This is the level of output ECDAT should aim for.

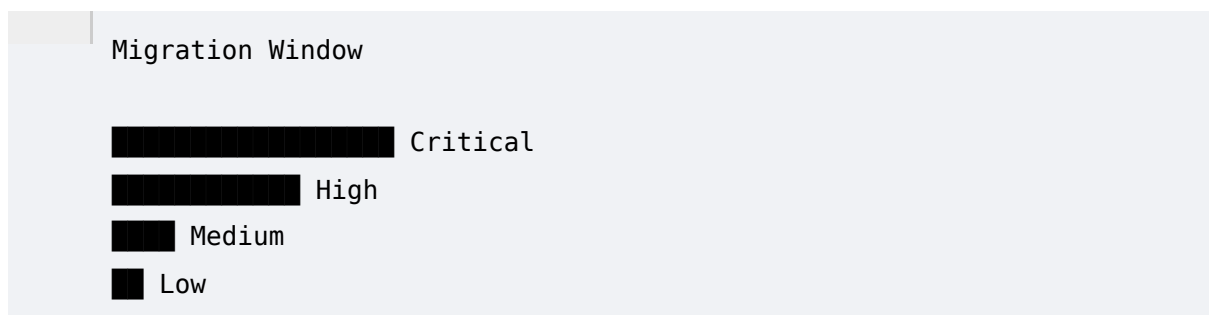
60. Enterprise Risk Dashboard

A high-level dashboard could show:

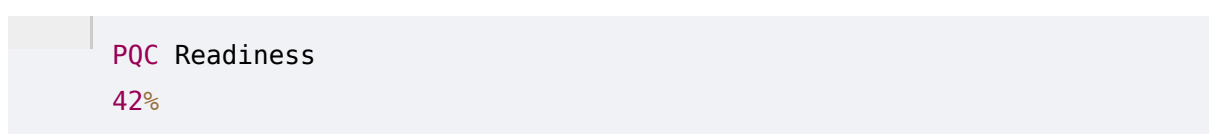


218	1,842	7,231	21,090
-----	-------	-------	--------

Then:



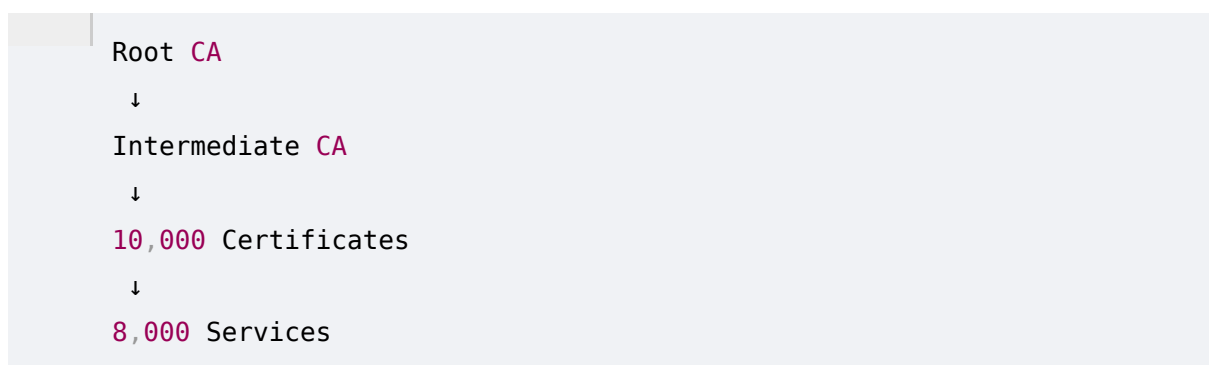
And:



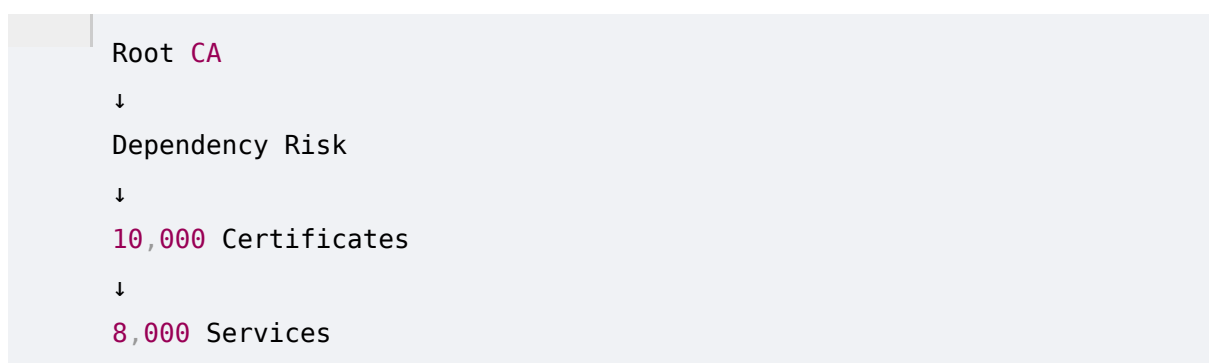
These numbers would be generated from actual inventory data, not manually assigned.

61. Risk Propagation Through a Graph

Suppose:



If the Root CA has a major migration blocker:



The risk engine can identify the **blast radius**.

This is extremely valuable.

62. "What Breaks If This Crypto Breaks?"

This should become one of ECDAT's strongest features.

Security administrators should be able to select:

```
RSA-2048
```

and ask:

```
What depends on this?
```

ECDAT responds:

```
RSA-2048
```

```
|  
├─ Certificate A  
├─ Certificate B  
├─ Payment API  
├─ VPN Gateway  
├─ 42 Services  
└─ 17 Business Processes
```

This transforms cryptographic discovery into dependency intelligence.

63. Scenario Analysis

Risk should support scenarios.

Example:

```
Scenario A:  
Quantum capability arrives later.
```

```
Scenario B:  
Quantum capability arrives earlier.
```

```
Scenario C:  
Migration takes twice as long.
```

```
Scenario D:  
PQC standard changes.
```

ECDAT can calculate how priorities change.

64. Best-Case Scenario

Assume:

Quantum threat:

Later

Migration:

Fast

PQC adoption:

High

The risk ranking may be less aggressive.

65. Expected Scenario

Use the organization's current best estimate.

Threat:

Expected

Migration:

Current estimate

PQC:

Standardized

This becomes the default planning scenario.

66. Worst-Case Scenario

Assume:

Quantum threat:

Earlier

Migration:

Delayed

Legacy systems:
Remain

This reveals assets that could become critical under adverse assumptions.

This is extremely useful for strategic planning.

67. Threat Horizon Uncertainty

ECDAT should never claim:

"Quantum computers will break RSA in exactly 14 years."

That would create false precision.

Instead:

Threat Horizon:
Scenario Range

Confidence:
Medium

Planning Assumption:
Conservative

This is more scientifically responsible.

68. Risk Decay and Time

Risk is dynamic.

As time passes:

2026

Threat Horizon:
Far

2030

Threat Horizon:
Closer

2035

Threat Horizon:
Much Closer

If migration has not progressed, risk increases.

Therefore ECDAT should periodically recalculate risk.

69. Migration Deadline

For an asset:

```
Data Lifetime = X
Migration Time = Y
Threat Horizon = Z
```

ECDAT can derive a strategic deadline.

Conceptually:

```
Migration should complete before:
Threat Horizon - Required Buffer
```

The exact buffer should be configurable.

70. Technical Debt

Crypto technical debt occurs when an organization continues using:

- Hardcoded algorithms
- Legacy libraries
- Old certificates
- Non-agile protocols
- Unsupported hardware

This creates future migration cost.

ECDAT can calculate:

```
Crypto Technical Debt
```

based on:

```
Legacy Assets
+
Migration Complexity
+
Dependency Count
```

+
Lack of Crypto-Agility

71. Quantum Exposure Score

ECDAT could maintain a separate score:

QES — Quantum Exposure Score

Example conceptual dimensions:

- Algorithm Vulnerability
- Data Lifetime
- Data Sensitivity
- Exposure

The score might be normalized:

0–100

For example:

QES = 91

But the system must explain how it arrived there.

72. Migration Readiness Score

Another metric:

MRS — Migration Readiness Score

Possible factors:

- PQC Support
- Crypto-Agility
- Dependency Documentation
- Testing Capability
- Vendor Support
- Inventory Completeness

Example:

Migration Readiness:

34/100

Low score means migration is difficult.

73. Crypto-Agility Score

Possible dimensions:

- Algorithm configurable
- Provider abstraction
- Automated certificate rotation
- PQC-capable libraries
- Modern protocols
- Upgradeable hardware

A highly agile application might score:

90/100

A rigid legacy appliance:

15/100

Again, the scale must be documented and calibrated.

74. Overall Quantum Readiness

At enterprise level:

- Quantum Readiness
 - =
 - Inventory
 - +
 - Risk Management
 - +
 - PQC Adoption
 - +
 - Crypto-Agility
 - +
 - Migration Progress

Possible dashboard:

Quantum Readiness:

58%

Inventory:

82%

PQC Adoption:

31%

Crypto-Agility:

47%

Migration Progress:

22%

This provides an executive-level view.

75. Executive Reporting

Executives do not need:

```
EVP_EncryptInit_ex()
```

They need:

"27% of critical cryptographic infrastructure requires migration planning."

A good ECDAT report should provide:

Executive Summary

What is the organization's quantum posture?

Critical Risks

What needs immediate attention?

Migration Exposure

How difficult will migration be?

Financial Impact

What resources may be required?

Timeline

When should migration begin?

Recommendations

What should leadership approve?

76. Risk Explainability

Every score must answer:

Why?

Example:

Risk:

Critical

Why?

1. RSA-based signature
2. Critical trust infrastructure
3. 30-year data/trust lifetime
4. 8-year migration estimate
5. Low crypto-agility
6. High dependency centrality
7. Conservative quantum scenario

This is much more defensible.

77. Evidence-Based Scoring

ECDAT should store:

Finding

↓

Evidence

↓

Reasoning

↓

Score

Example:

Evidence:

Certificate parser detected ECDSA P-256.

Evidence:
Application uses certificate for TLS.

Evidence:
Application classified as critical.

Evidence:
Data retention = 15 years.

Then:

Risk:
High

This is auditable.

78. Avoiding Arbitrary AI Scores

A dangerous design would be:

LLM:
"This seems high risk."

and then:

Risk = 87

This is not defensible.

Instead:

Deterministic Evidence
+
Defined Risk Model
+
AI Explanation

The AI should help interpret and explain the result, not invent the underlying risk.

79. AI's Role in Risk Assessment

AI can still be extremely powerful.

For example, it can help determine:

"This RSA key appears to protect a long-lived government archive based on surrounding configuration and application documentation."

Or:

"The cryptographic library is indirectly used through a framework abstraction."

The system can then combine that inference with deterministic evidence.

Architecture:



80. Requirements Derived From Phase 6

ECDAT should now support:

Risk

- Quantum vulnerability classification
- Mosca analysis
- HNDL assessment
- Data lifetime
- Migration time
- Threat horizon
- Business criticality
- Exposure
- Migration complexity
- Dependency centrality
- Confidence

Analytics

- Quantum Exposure Score
- Migration Readiness Score
- Crypto-Agility Score
- Overall Quantum Readiness

Planning

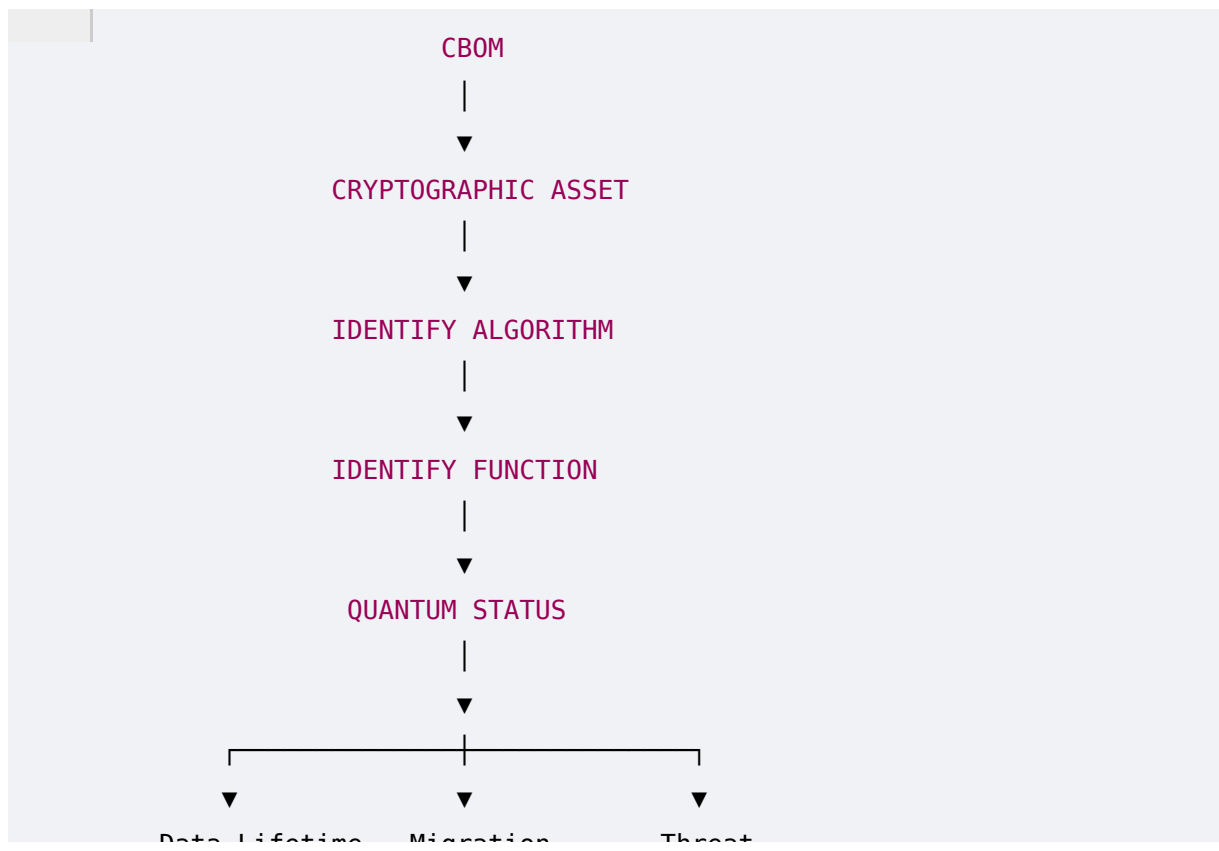
- Prioritization
- Scenario analysis
- Migration deadlines
- Risk propagation
- Blast-radius analysis

Reporting

- Executive dashboard
- Technical report
- Asset-level explanation
- Evidence-backed scoring

81. Complete Risk Pipeline

The entire Phase 6 engine can now be represented as:



82. Phase 6 Summary

Phase 6 transforms ECDAT from an inventory system into a **risk intelligence platform**.

The central lesson is:

Not every quantum-vulnerable cryptographic asset is equally urgent.

Risk depends on:

- Algorithm
- +
- Function
- +
- Data
- +
- Lifetime
- +
- Business Criticality
- +
- Exposure
- +
- Migration Complexity
- +
- Dependency
- +
- Threat Horizon

The most important strategic model is:

$$X + Y > Z$$

where:

- X = Information lifetime
- Y = Migration time
- Z = Quantum threat horizon

combined with:

HNDL

+

Business Impact

+

Migration Complexity

83. The Real Power of ECDAT

At this point the platform can conceptually answer:

"What cryptography do we have?"

Phase 5.

Now it can also answer:

"Which cryptography matters most?"

Phase 6.

The next question becomes:

"What exactly should we replace it with, and how should we migrate?"

That is where the next phase begins.

PHASE 7 PREVIEW — PQC RECOMMENDATION ENGINE & ALGORITHM SELECTION

Phase 7 will build the decision layer that sits after the risk engine.

We will go deeply into:

- Mapping legacy algorithms to PQC alternatives
- KEM vs digital signature decisions
- ML-KEM
- ML-DSA
- SLH-DSA
- Hybrid cryptography
- Algorithm selection
- Security levels
- Performance
- Key sizes

- Signature sizes
- Ciphertext sizes
- Latency
- Memory
- Hardware support
- HSM compatibility
- TLS compatibility
- PKI compatibility
- Cloud support
- Application constraints
- Embedded-system constraints
- Migration complexity
- Vendor constraints
- Crypto-agility
- Policy-based recommendations
- Multi-objective optimization
- Recommendation confidence
- Explainable recommendations
- "Why this algorithm?"
- "Why not this algorithm?"
- Alternative recommendations
- Migration sequencing
- Automated migration plans

The ultimate goal will be to make ECDAT capable of taking:

ECDSA P-256

+

Critical Application

+

15-Year Data

+

High Migration Complexity

+

TLS

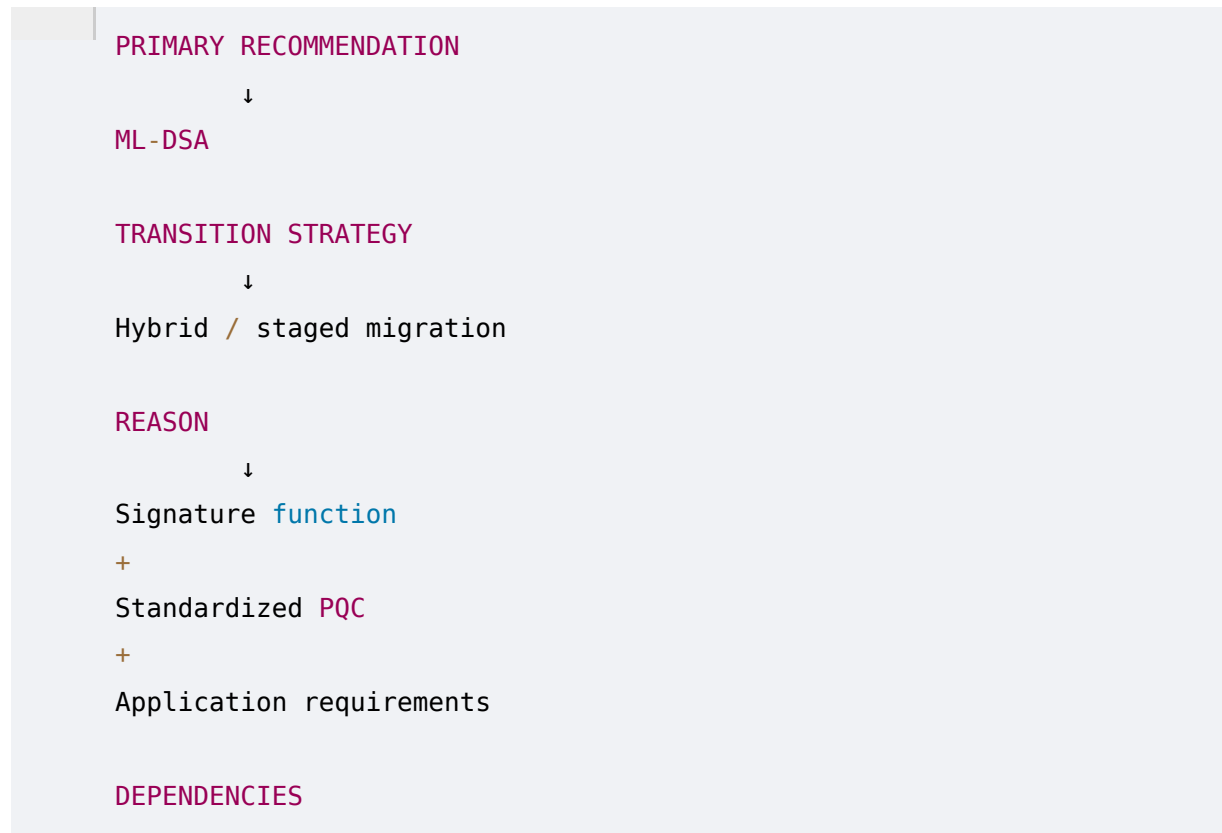
+

HSM Dependency

and producing something far more intelligent than:

"Replace with ML-DSA."

Instead:



That recommendation engine is where ECDAT starts becoming genuinely differentiated from a conventional CBOM scanner.

Phase 6 complete.